AlerGica

DOCUMENTO DE ARQUITETURA



Arquitetura do Sistema

Visão completa da arquitetura de software do AlerGica — componentes, dados, integrações, segurança, implantação e evolução.

VERSÃO	ATUALIZADO EM	PÚBLICO	CLASSIFICAÇÃO
1.8.0	12 de novembro de 2026	Arquitetos, CTOs e due diligence técnica	Confidencial

Sumário

1. Sumário executivo

2. Princípios arquiteturais

3. Visão de contexto

4. Visão de containers

5. Arquitetura do frontend

- 5.1 Camadas
- 5.2 Mapa de rotas
- 5.3 Navegação no painel
- 5.4 Gerenciamento de estado

6. Arquitetura de backend

- 6.1 Supabase (caminho principal)
- 6.2 API FastAPI (camada de servidor)

7. Integrações externas

- 7.1 Feed de estudos científicos

8. Arquitetura de dados

- 8.1 Visão geral
- 8.2 Origem do catálogo de medicamentos
- 8.3 Modelo normalizado (evolução multi-alérgeno)

9. Regras de negócio centrais

- 9.1 Classificação de risco
- 9.2 Destaque de excipientes lácteos
- 9.2.1 Alergias do perfil (multi-alérgeno)
- 9.2.2 Bulas guardadas e atualização
- 9.3 Alternativas seguras
- 9.4 Popularidade
- 9.5 Personalização por perfil

10. Segurança

- 10.1 Autenticação

10.2 Autorização (RLS e papéis)

10.3 Segredos e configuração

10.4 Privacidade e LGPD

11. Implantação e operação

12. Roteiro de evolução arquitetural

13. Dívida técnica e riscos conhecidos

13.1 Itens resolvidos

13.2 Itens em aberto

14. Histórico de revisões

Arquitetura do Sistema AlerGica

1. Sumário executivo

O **AlerGica** é uma plataforma web (SPA, *mobile-first*) que ajuda famílias de crianças com **APLV — Alergia à Proteína do Leite de Vaca** a identificar medicamentos e produtos seguros. O núcleo do produto é um **catálogo de medicamentos com classificação de risco** (seguro / atenção / risco), extraída das bulas oficiais, complementado por:

- busca instantânea por nome comercial, genérico ou composição;
- página de detalhe com composição, excipientes de origem láctea destacados e link para a bula original;
- **sugestão automática de alternativas seguras** (mesmo princípio ativo, outro fabricante, sem leite);
- verificação de **produtos alimentícios por foto** do rótulo, com análise por IA;
- conteúdo educativo com fontes científicas e feed de estudos recentes traduzidos para português;
- perfil do usuário, cadastro de bebês e canal de suporte/sugestões.

A arquitetura é **serverless-first**: o frontend React é servido estaticamente (Vercel) e conversa diretamente com o **Supabase** (PostgreSQL + Auth + API REST automática), com a segurança garantida por **Row-Level Security (RLS)** no banco. Integrações de IA são orquestradas por **n8n** via webhooks. Há ainda um serviço **FastAPI** (Python) preparado para regras de negócio no servidor, hoje em estágio inicial.

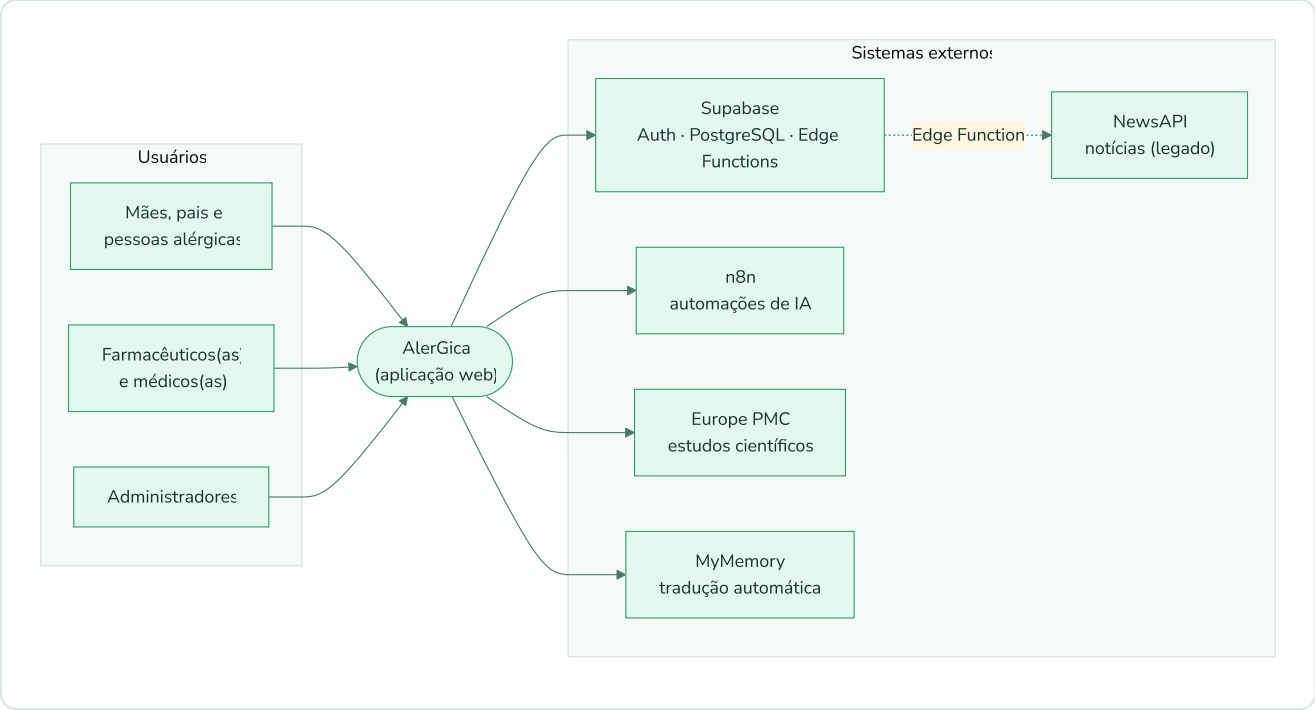
Atributo	Decisão
Estilo arquitetural	SPA + Backend-as-a-Service (BaaS) + automações por webhook
Linguagens	TypeScript (frontend, Edge Functions), Python (API FastAPI), SQL (banco)
Banco de dados	PostgreSQL gerenciado (Supabase)
Autenticação	Supabase Auth (e-mail e senha, JWT)
Autorização	RLS por usuário + papéis (`admin` , `moderator` , `user`)
Hospedagem	Vercel (frontend) · Supabase Cloud (dados, auth, funções)
IA	n8n (webhooks) para análise de alergias e leitura de rótulos
Idioma da interface	Português do Brasil

2. Princípios arquiteturais

1. **Segurança no dado, não só na tela.** Toda tabela tem RLS ativada. Mesmo que o frontend seja contornado, o banco só entrega o que o usuário autenticado pode ver.
2. **Camada de serviços no frontend.** Componentes de tela não falam com APIs diretamente: chamam funções em `src/services/`, que concentram consultas, regras de classificação e integrações.
3. **Menor infraestrutura possível.** Sem servidores próprios para operar no caminho crítico: o Supabase expõe o banco por REST e o frontend é estático. Isso reduz custo e superfície operacional.
4. **Falhar de forma segura.** Em uma aplicação de saúde, a dúvida deve resultar em "Atenção", nunca em "Seguro". A regra de classificação usa `caution` como padrão quando os dados são insuficientes.
5. **Extensível para outros alérgenos.** O modelo normalizado (`allergen_groups`, `ingredients`, `medication_ingredients`) já prevê glúten, soja, ovo e lactose, permitindo expandir além da APLV.
6. **Português em primeiro lugar.** Toda a interface, mensagens de erro e conteúdo científico (traduzido automaticamente) estão em pt-BR.

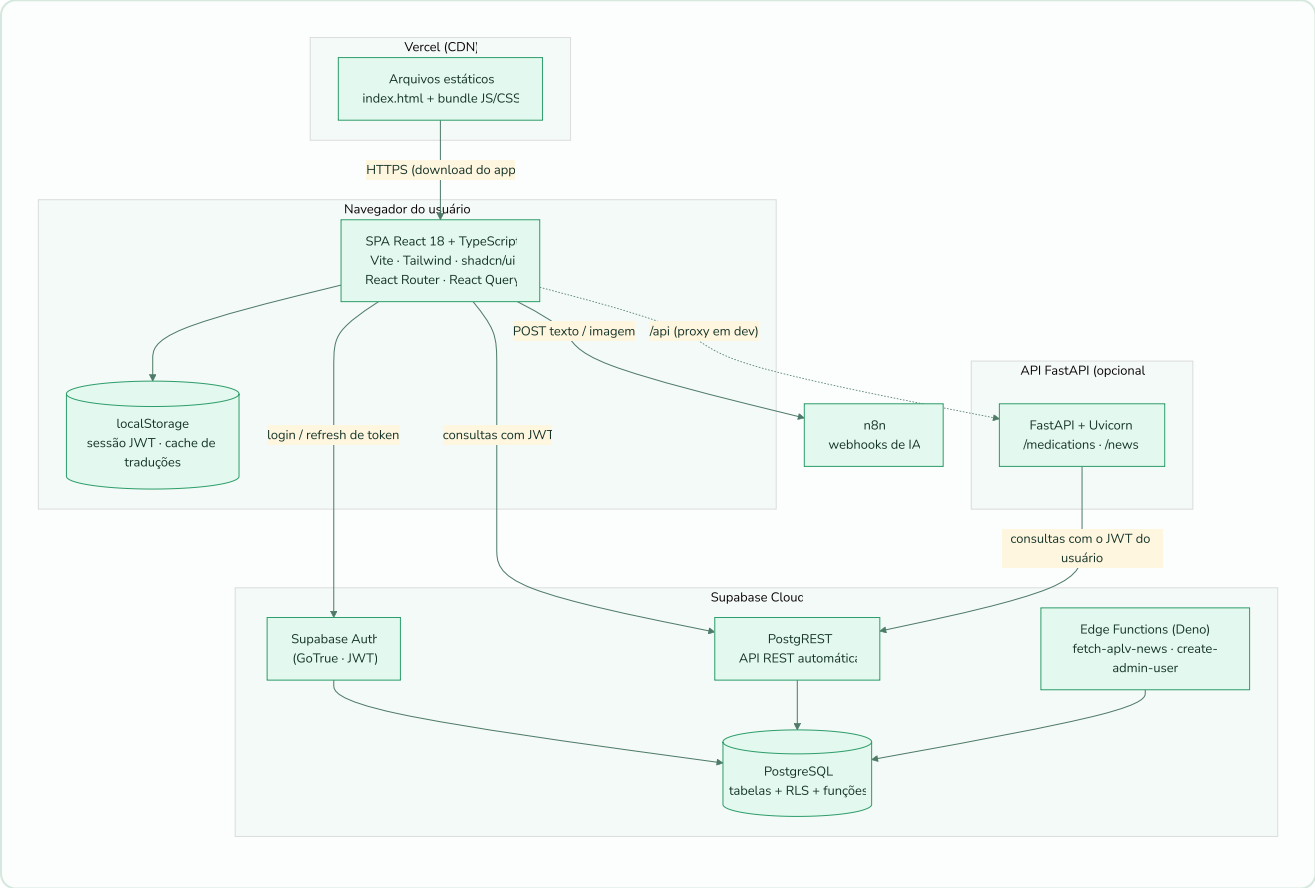
3. Visão de contexto

Quem usa o sistema e com quais sistemas externos ele se relaciona.



Ator / sistema	Papel
Mães, pais, pessoa alérgica	Público principal. Consulta medicamentos, verifica produtos, gerencia perfil e bebês.
Profissionais de saúde	Mesmo acesso, com interface ajustada (ocultação de pontos de análise da IA voltados a leigos).
Administradores	Gerenciam catálogo e papéis via banco (políticas `admin`).
Supabase	Autenticação, banco PostgreSQL, API REST (PostgREST), funções RPC e Edge Functions.
n8n	Recebe texto/imagem por webhook e devolve análise por IA (perfil de alergias e leitura de rótulos).
Europe PMC	Fonte pública (indexa o PubMed) dos estudos recentes exibidos na tela inicial.
MyMemory	Tradução dos títulos dos estudos do inglês para o português.
NewsAPI	Fonte de notícias usada pela Edge Function `fetch-aplv-news` (não exibida na versão atual).

4. Visão de containers

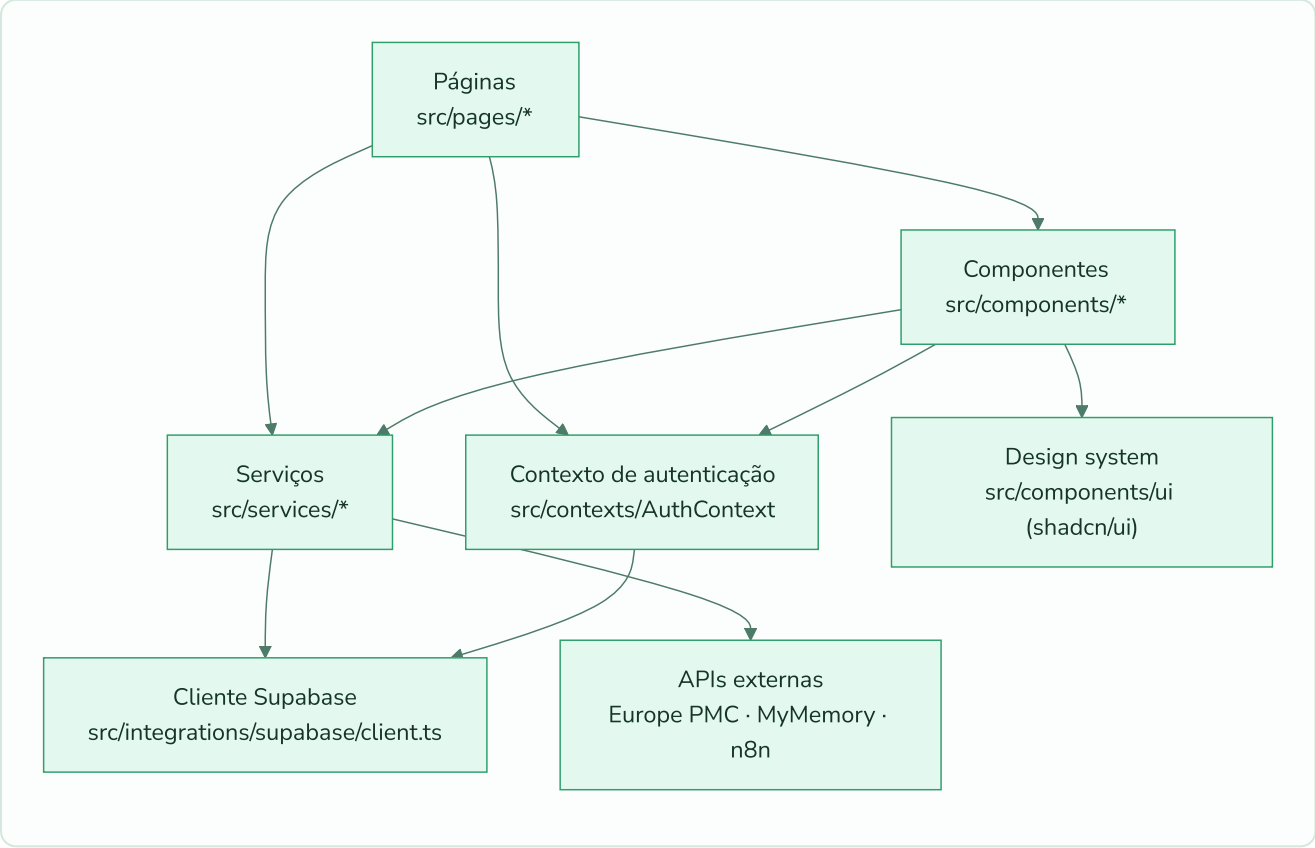


Container	Tecnologia	Responsabilidade	Estado
SPA	React 18, TypeScript, Vite 5	Interface, roteamento, regras de apresentação e classificação de risco	Produção
Hospedagem estática	Vercel	Entrega do app; reescreve todas as rotas para `index.html`	Produção
Supabase Auth	GoTrue	Cadastro, login, emissão e renovação de JWT	Produção
PostgREST	Supabase	Expõe as tabelas como API REST, aplicando RLS	Produção
PostgreSQL	Supabase	Dados de usuários, catálogo, conteúdo e auditoria básica	Produção
Edge Functions	Deno	Cache de notícias; criação de administradores (restrita a `admin`)	Implantadas, uso pontual
API FastAPI	Python 3, FastAPI	Camada de regras de negócio no servidor	Em desenvolvimento — ainda não usada pelo frontend

Container	Tecnologia	Responsabilidade	Estado
n8n	n8n (externo)	Orquestra chamadas de IA	Produção (dependência externa)

5. Arquitetura do frontend

5.1 Camadas



Camada	Pasta	O que contém
Entrada	`src/main.tsx`, `src/App.tsx`	Montagem do React, provedores globais (React Query, Tooltip, Auth, Toasts) e rotas
Páginas	`src/pages/`	Uma tela por rota: autenticação, painel, detalhe do medicamento, perfil, configurações, 404
Componentes	`src/components/`	Blocos de interface reutilizáveis (cards, barra lateral, menu inferior, scanner, widget de suporte)
Design system	`src/components/ui/`	Componentes base shadcn/ui sobre Radix UI
Serviços	`src/services/`	Acesso a dados e regras: `medications.ts`, `studies.ts`, `api.ts`
Contexto	`src/contexts/AuthContext.tsx`	Sessão, usuário, flag de administrador, login/cadastro/saída
Integração	`src/integrations/supabase/`	Cliente Supabase e tipos gerados do banco

Camada	Pasta	O que contém
Estilos	`src/index.css`, `tailwind.config.ts`	Tokens de cor (claro/escuro), sombras, animações

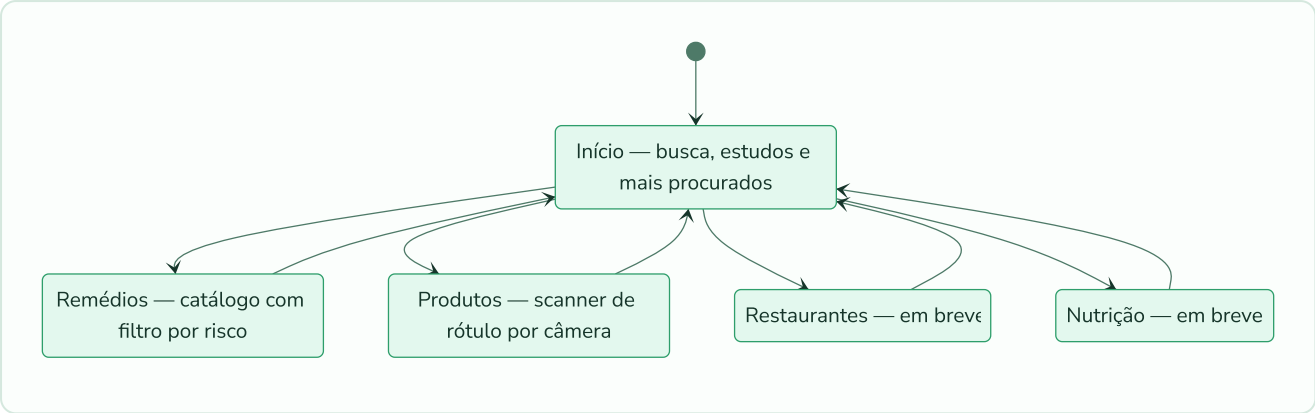
5.2 Mapa de rotas

Rota	Página	Acesso	Observação
`/`	`AuthPage`	Público	Login, cadastro (com consentimentos LGPD) e recuperação de senha; `?modo=cadastro` abre no cadastro
`/dashboard`	`Dashboard`	Autenticado	Módulos: Início, Remédios, Produtos, Restaurantes, Nutrição
`/medication/:id`	`MedicationDetails`	Autenticado*	Detalhe, composição e alternativas seguras
`/profile`	`ProfilePage`	Autenticado	Dados pessoais e bebês
`/settings`	`SettingsPage`	Autenticado	Privacidade e seus dados (LGPD) e preferências
`/privacidade`	`PrivacyPolicyPage`	Público	Política de Privacidade
`/termos`	`TermsPage`	Público	Termos de Uso
`/redefinir-senha`	`ResetPasswordPage`	Link do e-mail	Criação de nova senha após "Esqueci minha senha"
`/admin/mensagens`	`AdminMessagesPage`	Só `admin`	Caixa de Suporte, Sugestões e Feedback; quem não é administrador volta para `/dashboard` (o banco também bloqueia)
`*`	`NotFound`	Público	Página 404

* A página não redireciona sozinha quem não está logado; os dados continuam protegidos pela RLS do banco (a consulta retorna vazio). Ver seção 13.

5.3 Navegação no painel

O painel (`/dashboard`) é uma única página com **módulos** alternados pelo menu inferior expansível (`ExpandableTabs`). A troca de módulo não muda a URL — é estado local da página.



5.4 Gerenciamento de estado

- **Sessão:** `AuthContext` assina `onAuthStateChange` do Supabase e expõe `user`, `session`, `loading` e `isAdmin` (via RPC `has_role`). A sessão é persistida em `localStorage` com renovação automática do token.
- **Dados de tela:** estado local (`useState` / `useEffect`) por página. O `QueryClient` do TanStack React Query está configurado na raiz e disponível para adoção gradual.
- **Cache no navegador:** traduções de títulos de estudos ficam em `localStorage` (chave `alergica:study-title-pt`), mantendo apenas os estudos atuais.
- **Busca:** campo com *debounce* de 400 ms antes de consultar o banco.

6. Arquitetura de backend

6.1 Supabase (caminho principal)

O frontend usa o SDK `@supabase/supabase-js` para todas as operações de dados. Cada requisição carrega o JWT do usuário; o PostgREST repassa a identidade ao PostgreSQL, que aplica as políticas de RLS.

Recurso	Uso no AlerGica
Auth	Cadastro com e-mail e senha, login, sessão persistente. Confirmação de e-mail está desativada (login automático após o cadastro).
PostgREST	Leitura do catálogo, CRUD de perfil, bebês, sugestões, feedback e onboarding.
Funções SQL (RPC)	`has_role` (verifica papel), `increment_medication_access` (contador de acessos), `handle_new_user` (gatilho de cadastro).
Gatilhos	Criação automática de perfil e papel `user` ao cadastrar; atualização de `updated_at`.
Edge Functions	`fetch-aplv-news` (notícias com cache de 24 h), `delete-account` (exclusão da conta pelo titular) e `create-admin-user` (criação de usuários e administradores; só pode ser chamada por um `admin` autenticado).
Storage	Previsto para imagens de solicitações de inclusão (`solicitado_inclusao.imagem_url`).

6.2 API FastAPI (camada de servidor)

Localizada em `backend/`, foi desenhada para concentrar regras de negócio no servidor, seguindo o padrão **routers finos → services**. Ela não cria um sistema de autenticação próprio: recebe o JWT do Supabase no cabeçalho `Authorization` e o repassa ao banco, de modo que a RLS continua valendo.

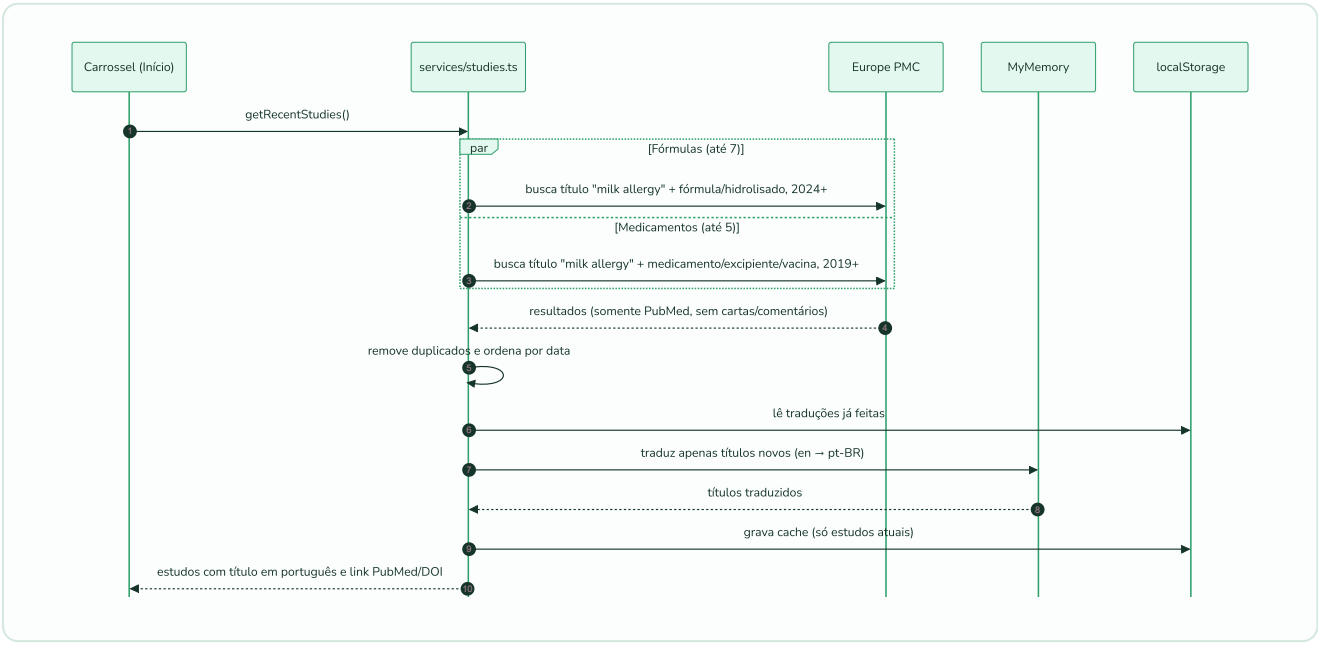
Endpoint	Descrição
`GET /medications/search?q=&limit=`	Busca medicamentos; sem `q`, devolve os 6 mais acessados
`GET /medications/{id}`	Detalhe com composição normalizada (ingredientes e grupos alergênicos)
`POST /medications/{id}/view`	Incrementa o contador de acessos
`GET /news`	Notícias sobre APLV via NewsAPI (chave guardada no servidor)

Em desenvolvimento, o Vite encaminha `/api/*` para `http://localhost:8000`. **Na versão atual o frontend não chama essa API** — todas as telas usam o Supabase diretamente. O plano de evolução (seção 12) prevê migrar a lógica de classificação e de alternativas para cá.

7. Integrações externas

Integração	Onde é usada	Protocolo	Autenticação	Comportamento em falha
n8n — perfil de alergias	Onboarding (`OnboardingModal`)	`POST` JSON `{ allergies }`	URL secreta do webhook (`VITE_N8N_WEBHOOK_URL`)	Mensagem de erro e opção de tentar de novo
n8n — leitura de rótulo	Módulo Produtos (`ProductScanner`)	`POST` multipart com a foto (`image`)	Mesmo webhook	Leitura local do rótulo no aparelho (Tesseract.js); erro só se as duas falharem
Tesseract.js (leitura local)	Reserva do scanner (`services/labelAnalysis.ts`)	Executa no navegador; baixa motor e idioma da CDN jsDelivr	Nenhuma	Tela de erro com "Tentar novamente" (ex.: sem internet na primeira vez)
Europe PMC	Carrossel de estudos (`services/studies.ts`)	`GET` REST público	Nenhuma	Categoria com erro é ignorada; restante é exibido
MyMemory	Tradução dos títulos dos estudos	`GET` REST público	Nenhuma	Mantém o título original em inglês (tempo limite de 4 s)
NewsAPI	Edge Function e FastAPI `/news`	`GET` REST	Chave no servidor (`NEWS_API_KEY`)	Lista vazia

7.1 Feed de estudos científicos

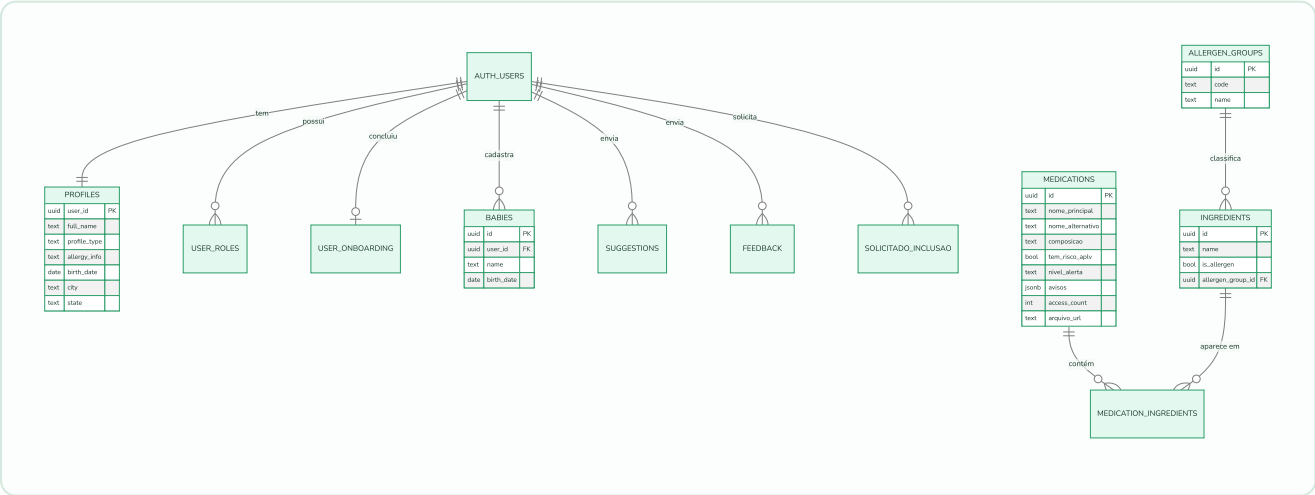


8. Arquitetura de dados

8.1 Visão geral

O banco tem dois grupos de tabelas:

- **Dados do usuário** — perfil, papéis, onboarding, bebês, sugestões e feedback. Cada linha pertence a um `user_id` e só o dono acessa.
- **Catálogo** — medicamentos (e, futuramente, produtos e restaurantes), legível por qualquer usuário autenticado e gravável apenas por administradores.



O dicionário de dados completo, coluna a coluna, está no documento **Documentação Técnica do Sistema**.

8.2 Origem do catálogo de medicamentos

O catálogo em produção é alimentado por um **processo de extração de bulas** (fora deste repositório): cada bula oficial é lida, a composição é separada em princípio ativo e excipientes, e uma análise identifica termos lácteos. O resultado preenche:

Campo	Conteúdo
`composicao`	Texto da composição: ativos, depois `. Excipientes:` e a lista
`termos_encontrados`	Termos de origem láctea encontrados na bula
`tem_risco_aplv`	`true` se contém leite, `false` se não contém, `null` se indefinido
`nivel_alerta`	Rótulo textual (ex.: `VERDE`, `AMARELO`, `VERMELHO`)

Campo	Conteúdo
`avisos`, `detalhes_criticos`, `detalhes_atencao`	Mensagens da análise por IA
`arquivo_url`, `data_extracao`	Link do PDF da bula e data da análise

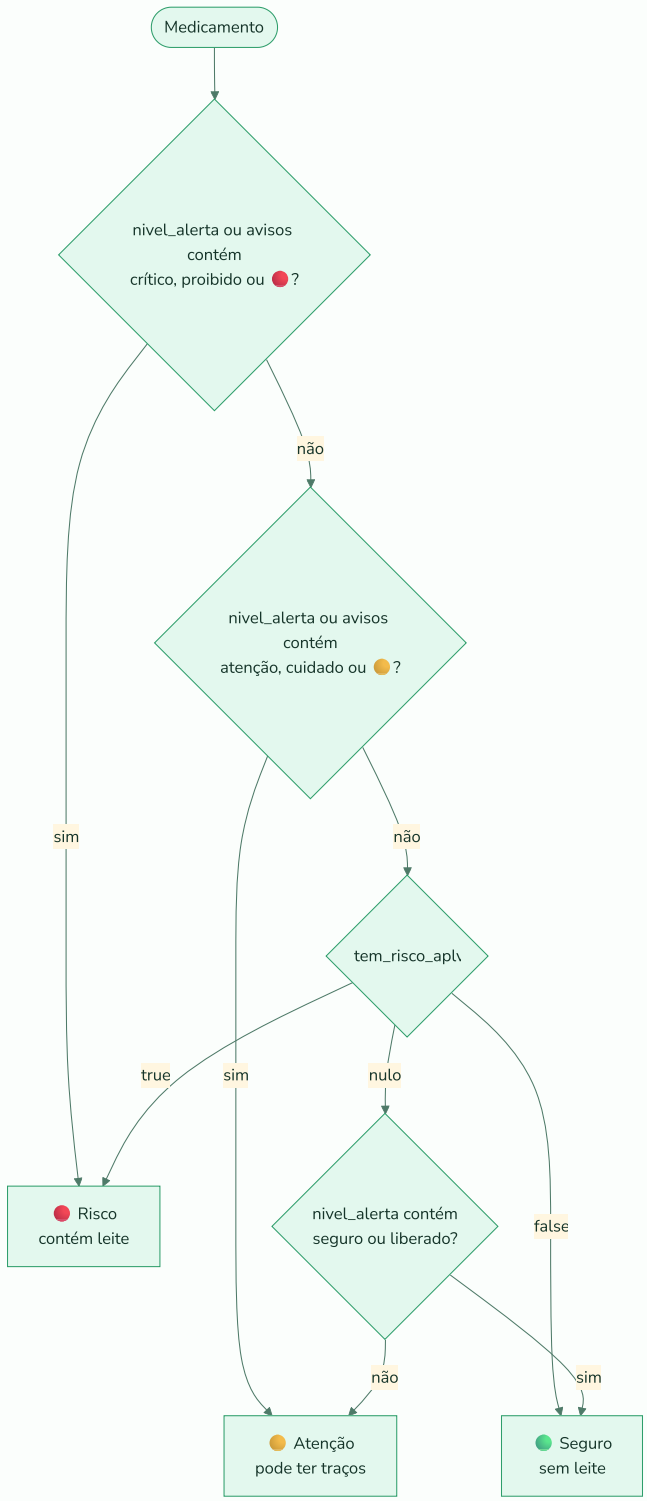
8.3 Modelo normalizado (evolução multi-alérgeno)

As migrações também criam um modelo normalizado — `allergen_groups` → `ingredients` → `medication_ingredients` — com grupos pré-cadastrados para **leite (MILK)**, **lactose**, **glúten**, **soja** e **ovo**. Esse modelo é a base para a fase de múltiplas alergias: em vez de procurar palavras na composição, cada ingrediente aponta para o grupo alergênico, e a classificação passa a ser calculada conforme as alergias do perfil.

9. Regras de negócio centrais

9.1 Classificação de risco

A função `medToRisk` (`src/services/medications.ts`) converte os campos do catálogo em um dos três níveis exibidos ao usuário. A ordem das verificações importa: sinais de risco vencem sinais de segurança, e a ausência de informação resulta em **Atenção**.



Nível	Código	Cor	Mensagem ao usuário
Seguro	`safe`	Verde	"Sem derivados do leite"
Atenção	`caution`	Amarelo	"Verifique com o farmacêutico"
Risco	`risk`	Vermelho	"Contém derivados do leite"

9.2 Destaque de excipientes lácteos

Na página de detalhe, a composição é dividida em **princípio ativo** e **excipientes**. Cada excipiente é comparado (sem acentos, sem diferenciar maiúsculas) com uma lista de termos lácteos — leite, lactose, caseína, caseinato, lactoalbumina, lactoglobulina, soro de leite, whey, manteiga, lactulose — somada aos termos que a análise da bula encontrou. Os que batem são destacados em vermelho.

9.2.1 Alergias do perfil (multi-alérgeno)

Cadastro e perfil. O usuário marca alergias em duas listas — **10 alimentares** (leite/APLV, ovo, soja, trigo/glúten, amendoim, castanhas e nozes, peixe, crustáceos, gergelim, milho) e **10 classes de medicamentos** (penicilinas, cefalosporinas, sulfas, anti-inflamatórios, AAS, dipirona, paracetamol, macrolídeos, quinolonas, anticonvulsivantes) — e escreve o que não estiver nelas em **Outros**. O texto de "Outros" é reconhecido por apelidos (ex.: "amoxicilina" → Penicilinas; "tartrazina" → Corantes; "tramadol" → Opioides); o que não é reconhecido vira **termo próprio**, procurado como escrito. Os ids marcados ficam em `profiles.food_allergies` / `drug_allergies` (`text[]` , índice GIN — permite consultar usuários por alergia) e o texto em `allergy_info` . Catálogo em `src/lib/allergens.ts` . Perfil sem alergias usa o padrão **APLV**.

Regra única de risco (`src/lib/medicationRisk.ts` , `assessMedication`) — usada nas listas, na busca, no detalhe e nas alternativas, para que o selo da lista e a página do remédio sempre concordem. Princípio: *na dúvida, Atenção*.

Verificação	Fonte	Resultado
Leite (se estiver no perfil)	Catálogo: `tem_risco_aplv` , `nivel_alerta` , `avisos`	O do catálogo
Alergia alimentar do perfil	Palavra inteira na `composicao`	Encontrou → **Risco**
Alergia a medicamento / termo próprio	Nome + `nome_completo` + `composicao`	Encontrou → **Risco**
Ingrediente de origem não informada (ex.: "lecitina" para ovo/soja, "amido" para glúten/milho, "gelatina" para peixe)	`composicao` , por ingrediente	**Atenção**
Reação cruzada (penicilinas ↔ cefalosporinas; anti-inflamatórios ↔ AAS ↔ dipirona)	Nome + composição	**Atenção**
Composição ausente com alergias além de leite	—	**Atenção**
Bula trocada e análise ainda não conferida (`bula_reanalisar`)	Catálogo	**Atenção** (seção 9.2.2)

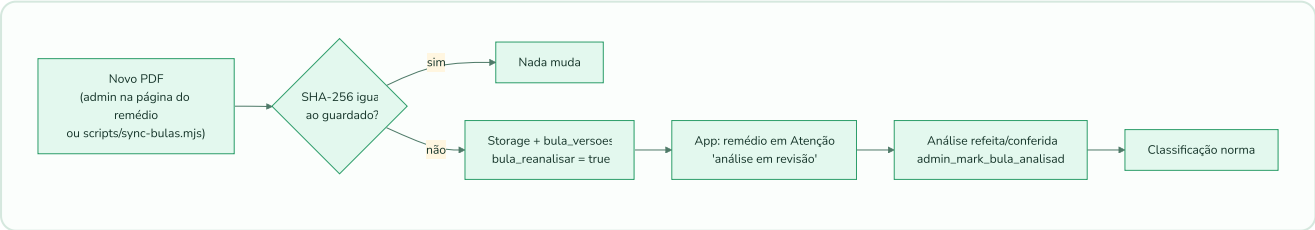
O pior resultado vence. **Seguro** só quando todas as alergias puderam ser verificadas e nada foi encontrado. Se o remédio tem leite mas leite não está no perfil, o detalhe mostra um aviso (sem pintar de vermelho). Enquanto as alergias do perfil carregam, nenhum veredito é exibido (listas mostram "Verificando...").

Listas filtradas. Sem alergias personalizadas, o banco filtra por `tem_risco_aplv`. Com outras alergias, a classificação depende da composição: o catálogo é lido inteiro em lotes (cache de 10 min na sessão) e filtrado no navegador pela mesma regra.

Scanner de produtos. Usa só as alergias alimentares e os termos próprios (sem alimentares, verifica leite) e envia a lista ao n8n no campo `allergies`.

9.2.2 Bulas guardadas e atualização

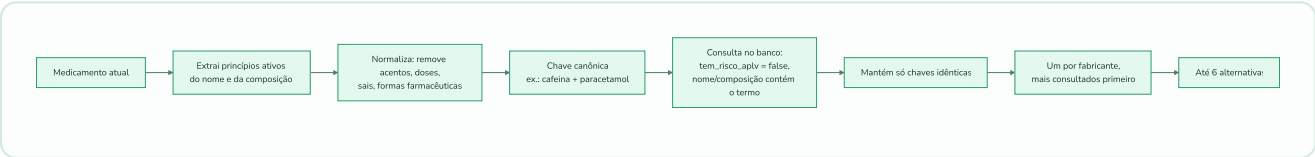
As bulas analisadas passam a ser guardadas pelo próprio AlerGica no **Supabase Storage** (bucket público `bulas`, só administradores gravam), em `<medication_id>/<sha256>.pdf`. O app abre a cópia guardada num visualizador interno (`BulaViewer`); `arquivo_url` fica como reserva e a busca no Bulário da Anvisa como conferência de versão mais nova.



Por que não é automático com a Anvisa: a Anvisa não oferece API pública para baixar bulas, e a consulta do Bulário bloqueia acesso automatizado (testado em 12/11/2026). A estrutura acima aceita qualquer fonte autorizada: hoje, envio pelo administrador ou pelo script em lote; no futuro, uma fonte autorizada (API oficial com credenciais Gov.br ou serviço contratado) pode alimentar o mesmo fluxo por uma tarefa agendada, sem mudar o app. **Regra de segurança:** bula diferente da analisada nunca aparece como "Seguro" até a análise ser conferida.

9.3 Alternativas seguras

Quando um medicamento é **Atenção** ou **Risco**, o sistema procura outros com **exatamente os mesmos princípios ativos** e sem leite.



A normalização ignora sais e hidratos (cloridrato, sódico, mono-hidratado...), formas (comprimido, gotas, xarope...), dosagens e prefixos de laboratórios públicos (ex.: `furp-`). A busca no banco ignora acentos trocando vogais e "c" por curinga de um caractere. A interface sempre alerta que dose, forma e indicação podem diferir e que a troca exige orientação profissional.

9.4 Popularidade

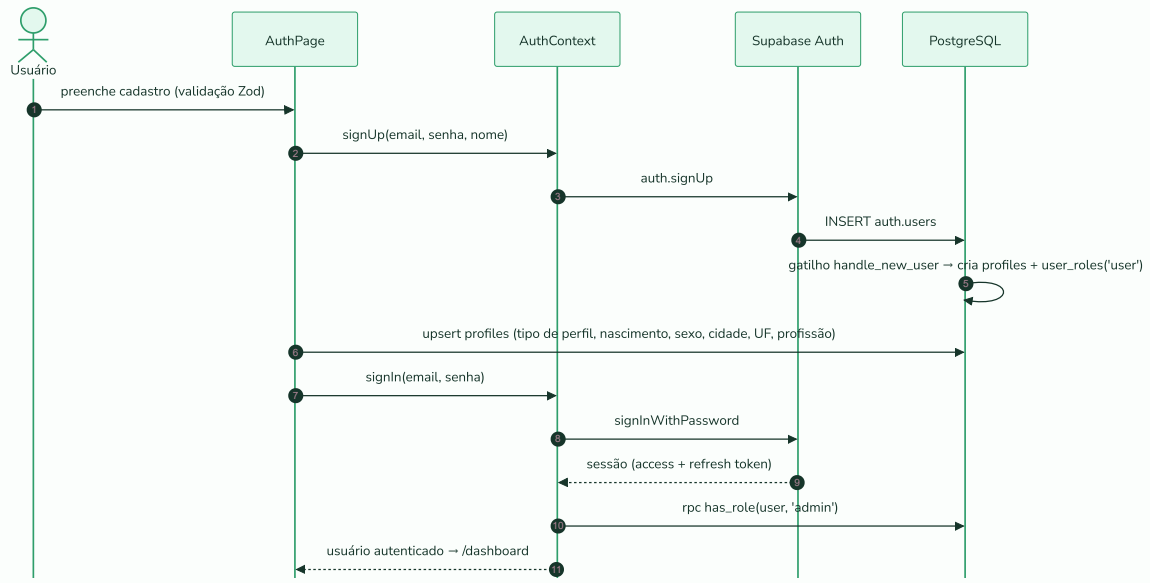
Cada abertura de detalhe chama a função `increment_medication_access` (RPC `SECURITY DEFINER`), que soma 1 em `access_count` sem dar ao usuário permissão de escrita na tabela. A seção "Mais Procurados" ordena por esse contador.

9.5 Personalização por perfil

Perfil (`profile_type`)	Efeito na interface
`mae`, `pai`	Exibe o gerenciador de bebês no perfil
`alergica`	Experiência padrão
`farmaceutico`, `medico`	Pula a etapa de IA do onboarding; oculta "Pontos críticos" e "Pontos de atenção" da análise automática no detalhe do medicamento

10. Segurança

10.1 Autenticação



- Senhas: mínimo de 8 caracteres (validação no cliente) e armazenamento com hash pelo Supabase Auth.
- Tokens: JWT de curta duração com *refresh token*, renovados automaticamente pelo SDK.
- Sessão persistida em `localStorage`.

10.2 Autorização (RLS e papéis)

Tabela	Leitura	Escrita
`profiles`, `babies`, `user_onboarding`	Somente o dono	Somente o dono
`user_consents`	O dono e `admin`	Inserção pelo dono (sem alteração ou exclusão)
`suggestions`, `feedback`	O dono e `admin`	Inserção pelo dono; `admin` altera o status
`user_roles`	O próprio usuário	Somente `admin`
`medications`, `ingredients`, `allergen_groups`, `medication_ingredients`	Qualquer usuário autenticado	Somente `admin`
`news_cache`	Público	Somente `admin` (e Edge Function com chave de serviço)

A página de mensagens do administrador lê os dados pela função `admin_list_messages()` (`SECURITY DEFINER` , recusa quem não é `admin`), que junta as mensagens com **apenas** o nome (`profiles.full_name`) e o e-mail (`auth.users`) de quem enviou — o administrador não ganha acesso às alergias e observações do perfil (dados de saúde, LGPD).

Papéis ficam em tabela separada (`user_roles` , enum `app_role`), e a checagem usa a função `has_role` com `SECURITY DEFINER` , o que evita recursão de políticas e impede que um usuário altere o próprio papel.

10.3 Segredos e configuração

Variável	Onde	Exposição
`VITE_SUPABASE_URL` , `VITE_SUPABASE_ANON_KEY`	Frontend	Pública por natureza (protegida por RLS)
`VITE_N8N_WEBHOOK_URL`	Frontend	Visível no navegador — ver seção 13
`SUPABASE_URL` , `SUPABASE_ANON_KEY` , `NEWS_API_KEY`	`backend/.env`	Apenas servidor
`SUPABASE_SERVICE_ROLE_KEY` , `NEWS_API_KEY`	Segredos das Edge Functions	Apenas servidor

Arquivos `.env` estão no `.gitignore` .

10.4 Privacidade e LGPD

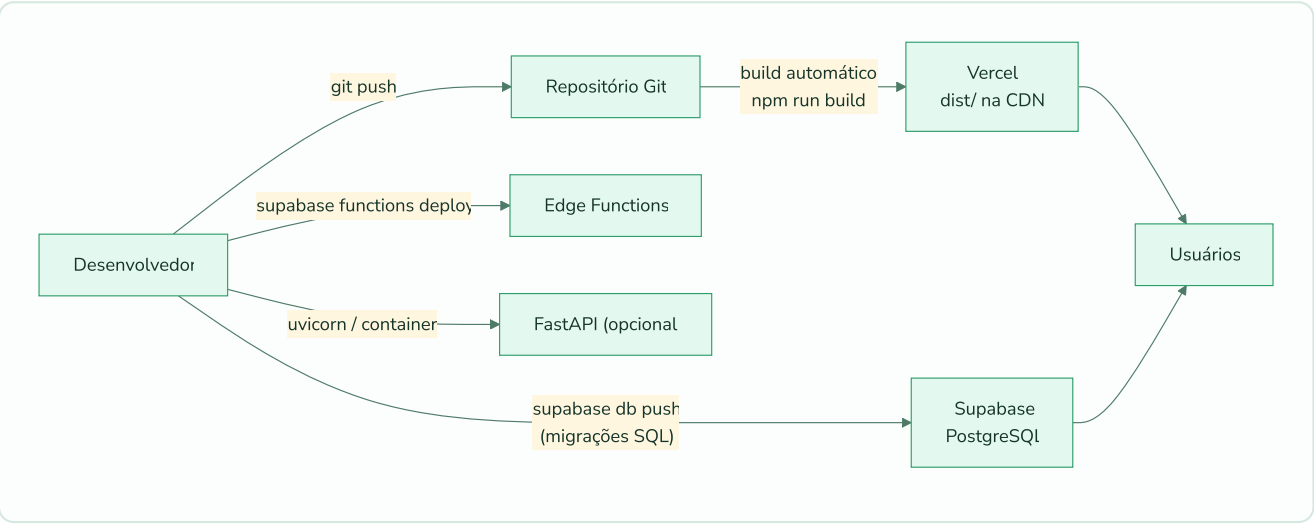
O sistema trata **dados pessoais sensíveis de saúde** (alergias, observações e dados de crianças), enquadrados nos arts. 11 e 14 da LGPD. Medidas implementadas:

Princípio / direito (LGPD)	Como o sistema atende
Consentimento específico e destacado (art. 11, I; art. 14, §1º)	Duas caixas obrigatórias no cadastro: Termos + Política e, em destaque, uso de dados de saúde (inclusive de crianças)
Prova do consentimento (art. 8º, §2º)	Tipo, versão e data gravados em `user_metadata.lgpd_consents` e no histórico `user_consents`
Necessidade / minimização (art. 6º, III)	Só nome, e-mail, senha, tipo de perfil e data de nascimento são obrigatórios; sexo, cidade, UF e profissão são opcionais; consultas de remédios não são ligadas ao usuário
Proteção de crianças (art. 14)	Conta só para maiores de 18 anos (validado pela data de nascimento); dados de crianças inseridos pelo responsável
Transparência (art. 9º)	Páginas públicas `/privacidade` e `/termos` ; avisos antes de enviar foto ou texto à IA; links no login, no menu e em Configurações
Acesso e portabilidade (art. 18, II e V)	"Baixar meus dados" gera um JSON com todos os dados da conta

Princípio / direito (LGPD)	Como o sistema atende
Correção (art. 18, III)	Edição em Meu Perfil
Eliminação e revogação (art. 18, VI e IX; art. 8º, §5º)	"Excluir conta" chama a Edge Function `delete-account`, que apaga todos os dados e o usuário
Encarregado (art. 41)	Contato exibido na Política e em Configurações (`src/config/legal.ts`)
Segurança (art. 46)	HTTPS, senhas com hash, RLS por usuário, segredos só no servidor

Pendências para a comercialização: preencher os dados do controlador e do encarregado em `src/config/legal.ts`; revisão jurídica dos textos; acordos de tratamento de dados (DPA) com Supabase, Vercel, n8n e o provedor de IA; registro das operações de tratamento (art. 37) e relatório de impacto (RIPD, art. 38) por envolver dados sensíveis; apagar arquivos do Storage na exclusão de conta.

11. Implantação e operação



Ambiente	Frontend	Backend
Desenvolvimento	`npm run dev` — Vite em `http://localhost:8080` (proxy `/api` → `:8000`)	Supabase Cloud; FastAPI com `uvicorn app.main:app --reload`
Pré-visualização local	`npm run build` + `node serve.mjs` em `http://localhost:3000`	—
Produção	Vercel (SPA com reescrita de rotas para `index.html`)	Supabase Cloud

- **Migrações:** um arquivo SQL por mudança em `supabase/migrations/`, nomeado por data e hora.
- **Escalabilidade:** frontend estático em CDN escala sem esforço; o gargalo potencial é o banco, que escala verticalmente no Supabase. As consultas do catálogo usam `ILIKE` e se beneficiam de índices trigram (`pg_trgm`) quando o catálogo crescer.
- **Observabilidade:** logs de Auth, PostgREST e Edge Functions no painel do Supabase; logs de acesso no Vercel. Não há APM nem rastreamento de erros no frontend (recomendado: Sentry ou similar).

12. Roteiro de evolução arquitetural

Fase	Entrega	Impacto na arquitetura
1 — Consolidação	Alinhar migrações ao banco de produção; regenerar tipos; proteger rotas no cliente	Reprodutibilidade do ambiente e onboarding de novos devs
2 — Servidor de regras	Mover classificação, alternativas e chamadas ao n8n para a FastAPI (ou Edge Functions)	Regras auditáveis e versionadas no servidor; segredo do webhook fora do navegador
3 — Multi-alérgeno	Classificação calculada pelo modelo `ingredients` × `allergen_groups` × alergias do perfil	Risco personalizado por pessoa (leite, soja, glúten, ovo…)
4 — Módulos	Produtos e restaurantes com catálogo próprio (tabelas `products` e `restaurants` já existem)	Reuso do mesmo motor de classificação
5 — Plataforma	API pública para parceiros (farmácias, clínicas), PWA offline, notificações	Gateway de API, chaves por parceiro, limites de uso

13. Dívida técnica e riscos conhecidos

Lista honesta do estado atual, para planejamento e due diligence. A severidade considera o impacto em um produto de saúde.

13.1 Itens resolvidos

Item	Severidade	Correção	Versão
A Edge Function `create-admin-user` aceitava chamadas de qualquer pessoa com a chave pública e podia criar administradores.	Crítica	A função valida o JWT de quem chama e exige o papel `admin` (`has_role`); responde 401 sem login válido e 403 para não administradores.	1.0.1
Quando a análise de rótulo falhava, o scanner exibia um resultado de demonstração como se fosse real.	Alta	Falhas (rede, webhook ausente ou resposta sem veredito) levam a uma tela de erro com "Tentar novamente"; nenhum resultado é inventado.	1.0.1
"Esqueci minha senha" não funcionava.	Média	Envio do link por e-mail (`resetPasswordForEmail`) e página `/redefinir-senha` .	1.1.0
Estatísticas do perfil eram números fixos de exemplo.	Baixa	Bloco removido; o topo do perfil mostra dados reais (nome, tipo de perfil, data de cadastro e completude).	1.2.0

- **Classificação só para APLV nas listas:** listas, busca e detalhe agora usam a mesma regra por usuário (`assessMedication`), considerando todas as alergias do perfil.

13.2 Itens em aberto

#	Item	Severidade	Recomendação
1	As migrações não reproduzem o banco de produção: a tabela `medications` em produção usa colunas em português (`nome_principal` , `composicao` ...), enquanto a migração cria colunas em inglês (`name` , `risk_level` ...). `products` , `restaurants` e `solicitado_inclusao` não têm migração. Em 12/11/2026 confirmou-se que o banco também não tinha as colunas extras de `profiles` , `user_consents` e `increment_medication_access` — corrigido pelo script `supabase/manual/2026-11-12_corrigir_perfil_lgpd_contador.sql` .	**Alta**	Gerar migração de base a partir do banco atual (`supabase db dump`) e regenerar `types.ts` .
2	A API FastAPI consulta as colunas em inglês e não funcionaria com o banco atual; também não há middleware de validação de JWT (o `python-jose` está instalado, mas não é usado).	Média	Ajustar ao esquema real e adicionar validação do JWT antes de colocar em uso.

#	Item	Severidade	Recomendação
3	A URL do webhook do n8n fica no código do navegador; qualquer pessoa pode chamá-la e consumir créditos de IA.	Média	Chamar o n8n a partir do servidor, com autenticação e limite de uso.
4	A rota `/medication/:id` não redireciona usuário deslogado (os dados seguem protegidos pela RLS).	Baixa	Criar um componente de rota protegida reutilizável.
5	O texto digitado na busca entra direto no filtro do PostgREST (`.or(...)`); vírgulas e parênteses podem quebrar a consulta.	Baixa	Escapar caracteres reservados ou usar uma RPC de busca.
6	Cobertura de testes automatizados mínima (apenas um teste de exemplo).	Média	Testes unitários para `medToRisk` , `activeKeysOf` e `getSafeAlternatives` ; testes E2E dos fluxos principais.
7	O `README.md` descreve componentes e recursos de versões anteriores (ex.: importação JSON pelo admin).	Baixa	Apontar o README para esta documentação.
8	"Suporte" no widget é gravado na tabela `suggestions` com o prefixo `[Suporte]` .	Baixa	Tabela ou canal próprio de atendimento.
9	Links de bula da Anvisa (`arquivo_url`) expiram. **Em andamento:** bulas guardadas no Storage (seção 9.2.2); falta preencher as cópias (script `bulas:sync`) e definir uma fonte autorizada para atualização automática.	Média	Rodar `npm run bulas:sync -- --from-urls` / `--dir` ; avaliar API oficial da Anvisa (Gov.br) ou serviço contratado para tarefa agendada.

14. Histórico de revisões

Versão	Data	Alterações
1.0.0	12/11/2026	Primeira versão completa do documento de arquitetura.
1.0.1	12/11/2026	Corrigidos os itens críticos de segurança (`create-admin-user`) e do scanner de produtos; nova seção 13.1 "Itens resolvidos".
1.1.0	12/11/2026	Novas rotas (`/privacidade` , `/termos` , `/redefinir-senha`), Edge Function `delete-account` , tabela `user_consents` e seção 10.4 reescrita com as medidas de LGPD implementadas; recuperação de senha resolvida.
1.2.0	12/11/2026	Estatísticas fictícias do perfil removidas (item resolvido na seção 13.1).
1.3.0	12/11/2026	Leitura local de rótulos (Tesseract.js) como reserva do n8n no módulo Produtos (seção 7).
1.4.0	12/11/2026	Item 1 da dívida técnica atualizado com as colunas ausentes no banco em produção e o script de correção.
1.5.0	12/11/2026	Nova seção 9.2.1: listas de alergias (10 alimentares, 10 de medicamentos e "Outros") no cadastro e no perfil; colunas `food_allergies` / `drug_allergies` ; regra única de risco por usuário (`assessMedication`) nas listas, detalhe, alternativas e scanner, com "Atenção" para ingredientes de origem duvidosa, reação cruzada e composição ausente.
1.6.0	12/11/2026	Rota `/admin/mensagens` (caixa de Suporte, Sugestões e Feedback); `suggestions` / `feedback` com status e leitura por `admin` ; função `admin_list_messages` (seções 5.2 e 10.2).
1.7.0	12/11/2026	Item 9 da dívida técnica: links de bula da Anvisa expiram; paliativo com busca no Bulário.
1.8.0	12/11/2026	Nova seção 9.2.2: bulas guardadas no Supabase Storage com versão (SHA-256), histórico, visualizador no app, atualização pelo administrador ou script e "Atenção" até a nova análise; item 9 da dívida técnica atualizado.